

Министерство образования Республики Беларусь

Учреждение образования
«БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ»

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

Лабораторная работа №4

по дисциплине «Проектирование защищенных интеллектуальных
информационных систем»

на тему «Безопасность работы удалённых серверов в сети Internet.
Часть 1. Анализ запросов из сети Internet»

Выполнил студент гр. 321701

Ковальчук В. Н.
Самович В. М.

Проверил

Сальников Д. А.

Минск 2026

Цель: получить практические навыки анализа журналов реального удалённого сервера, доступного из сети Internet, и увидеть, какой фоновый трафик получает любой публичный сервер.

Задание:

- а) Установить на удалённом сервере веб-сервер и разместить на нём тестовую страницу, доступную из сети Internet.
- б) Настроить систему журналирования на веб-сервере.
- в) Выполнить анализ данных логов различных подсистем, в том числе SSH и веб-сервера удалённого сервера, за несколько дней.
- г) Оформить отчёт о проделанной работе.

Постановка задачи. Используется реальный VPS (Ubuntu 24.04, IP-адрес 212.192.9.89) с доменным именем `test-lab4.work.gd`. На нём установлен веб-сервер Caddy с автоматическим сертификатом Let's Encrypt и тестовой страницей на React. Сервер намеренно оставлен открытым: вход `root` и вход по паролю по SSH включены, а администратор подключается по ключу через VPN (10.0.0.4). Так в журналах накапливается настоящий интернет-трафик, а не смоделированный.

Краткое описание веб-сервера

Caddy – веб-сервер, который сам получает и продлевает TLS-сертификаты Let's Encrypt. Он раздаёт собранную React-страницу по HTTPS, перенаправляет HTTP на HTTPS (ответ 308) и пишет каждый запрос одной JSON-строкой в `/var/log/caddy/access.log`. Конфигурация (Caddyfile) и скрипты развёртывания лежат в репозитории в каталоге Lab4.1-WebServer.

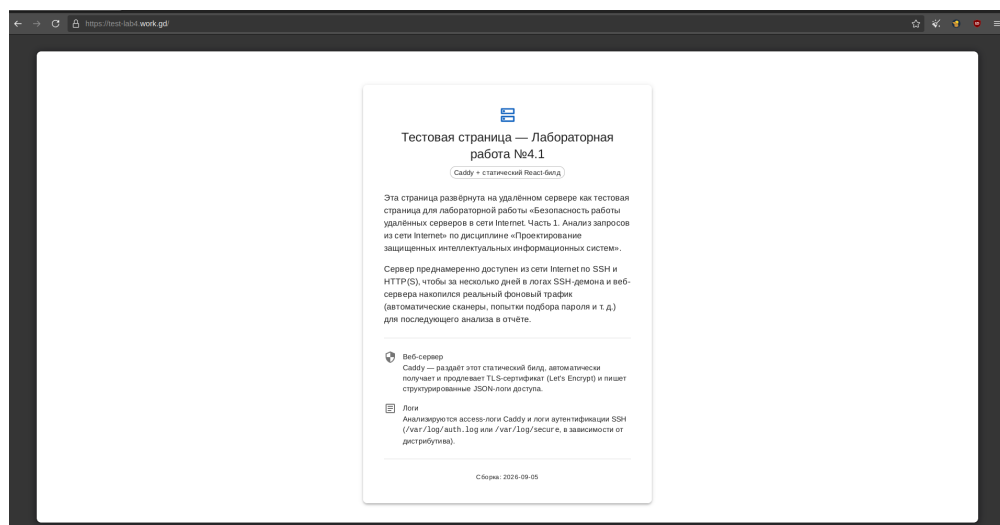


Рисунок 1 – Тестовая страница по адресу `https://test-lab4.work.gd/`

Краткое описание анализируемых файлов

– `/var/log/auth.log` – журнал аутентификации Ubuntu. Демон `sshd` пишет в него каждую попытку входа: `Accepted publickey/password` или `Failed password`, с именем пользователя, IP-адресом и временем.

– `/var/log/caddy/access.log` – журнал доступа Caddy: IP клиента, метод, путь, код ответа, `User-Agent`. По путям вроде `/.env` и `/.git/config` видно автоматические сканеры.

Примеры записей приведены в листинг 1.

```
1 == /var/log/auth.log (SSH) ==
2 2026-09-04T03:39:37.999168+00:00 weaselcloud-3522 sshd[4729]: Failed password for root from 36.69.158.203 port
   ↪ 36210 ssh2
3 2026-09-04T03:39:42.639743+00:00 weaselcloud-3522 sshd[4731]: Failed password for root from 36.69.158.203 port
   ↪ 38070 ssh2
4 2026-09-05T02:56:46.780373+00:00 weaselcloud-3522 sshd[73954]: Invalid user  from 45.153.34.235 port 57998
5 2026-09-20T00:05:19.628712+00:00 weaselcloud-3522 sshd[335272]: Failed password for invalid user hduser from
   ↪ 109.160.32.83 port 35410 ssh2
6
7 == /var/log/caddy/access.log (selected fields of the JSON records) ==
8 {"ts": 1788634194.214, "client_ip": "195.178.110.211", "method": "GET", "host": "test-lab4.work.gd", "uri":
   ↪ "/", "ua": "Mozilla/5.0 (compatible; CT-WP-Scanner/1.0; +https://example.com/bot)", "status": 200, "size":
   ↪ 332, "duration": 0.0097}
9 {"ts": 1788634226.394, "client_ip": "165.227.39.235", "method": "GET", "host": "test-lab4.work.gd", "uri":
   ↪ "/", "ua": "Mozilla/5.0 (19scan/2.0.9383e293e2239313e2231323; +https://leakix.net)", "status": 308,
   ↪ "size": 0, "duration": 8e-05}
10 {"ts": 1788634227.399, "client_ip": "165.227.39.235", "method": "GET", "host": "test-lab4.work.gd", "uri":
   ↪ "/console/", "ua": "Mozilla/5.0 (19scan/2.0.9383e293e2239313e2231323; +https://leakix.net)", "status":
   ↪ 308, "size": 0, "duration": 9e-05}
```

Листинг 1 – Примеры записей журналов

Анализ запросов из сети на SSH сервер и веб-сервер

Анализ выполнен скриптом `analyze.sh` (команды `grep`, `sort`, `uniq -c`, `jq`), который запускается на сервере. Все времена в UTC. Журналы ротируются, поэтому сводка по SSH «до» (3–5 сентября) сохранена с момента, когда эти данные ещё были на сервере, а сводка по веб-серверу снята сейчас по всему журналу (5 сентября – 8 октября).

SSH, 3–5 сентября (до установки OSSEC, 47,6 часа). Результаты в листинг 2, основное – в таблице.

Неудачных попыток входа	13 458 (283 в час)
Уникальных IP-адресов	64
Самый активный адрес	36.69.158.203: 7 002 попытки (52 %)
Попыток под именем <code>root</code>	9 652 (71,7 %)
Другие имена	<code>admin</code> , <code>user</code> , <code>deploy</code> , <code>ubuntu</code> , <code>test</code>
Успешные входы	44, все с адреса администратора

Таблица 1 – Попытки входа по SSH до установки OSSEC

```

1  Period: 2026-09-03 .. 2026-09-05 19:16 (OSSEC not yet installed)
2  Failed password attempts: 13458
3  Unique source IPs: 64
4  Attempts for root: 9652
5
6  Top 5 source IPs:
7      7002 36.69.158.203
8      784 45.153.34.235
9      784 91.92.42.52
10     501 91.92.40.45
11     501 91.92.40.27
12
13  Top 5 user names:
14     9652 root
15     567 admin
16     204 user
17     169 deploy
18     165 ubuntu
19
20  Failed attempts per day:
21     19 2026-09-03
22    9107 2026-09-04
23   4332 2026-09-05 (until 19:16)
24
25  Successful logins (method user ip):
26     38 publickey for root from 10.0.0.4
27      2 password for root from 10.0.0.4
28      4 password for root from 37.214.57.*** (administrator, first setup)

```

Листинг 2 – Сводка по SSH за 3–5 сентября

Перебор идёт круглосуточно, без дневного профиля, то есть это автоматические боты. В основном подбирают пароль `root`, остальные имена – стандартный словарь служебных учётных записей. Ни один из этих адресов не вошёл в систему, но только потому, что пароль `root` оказался стойким: вход `root` по паролю был разрешён.

Веб-сервер, 5 сентября – 8 октября (33 суток). Результаты в листинг 3.

- Всего 3 539 запросов с 217 адресов; 2 930 из них (83 %) – 404, настоящих загрузок страницы только 284 (200), и 30 запросов сделал сам администратор.

- Первый запрос пришёл в 18:49:54, в день запуска сервера, причём по доменному имени, а не по IP. Вероятно, адрес сканеры узнали из журналов Certificate Transparency, куда попадает каждый сертификат Let's Encrypt.

- Самые частые 404: `/robots.txt`, `/.git/config`, `/.env`, `/.env.production`, `/phpinfo.php` – поиск забытых файлов с паролями и ключами.

- Трафик идёт «пачками»: восемь адресов из диапазонов `34.x` и `35.x` (облачный хостинг) сделали по 277 запросов каждый (2 216 из 3 539, 63 %); в самый активный день, 21 сентября, было 842 запроса, в большинство дней – единицы.

- Часть запросов – от известного сканера LeakIX (User-Agent с `19scan`).

```

1 Requests: 3539    unique IPs: 217
2
3 Status codes:
4     2930 404
5     284 200
6     228 308
7     74 405
8     23 304
9
10 Top 10 client IPs:
11     277 35.215.236.50
12     277 34.87.64.148
13     277 34.85.46.13
14     277 34.85.4.70
15     277 34.81.62.102
16     277 34.81.190.215
17     277 34.80.253.162
18     277 34.67.111.71
19     263 136.65.161.239
20     120 45.138.12.24
21
22 Top 10 paths answered 404:
23     30 /robots.txt
24     29 /.git/config
25     23 /.env
26     15 /.env.production
27     14 /phpinfo.php
28     14 /info.php
29     13 /backend/.env
30     13 /app/.env
31     13 /api/session/properties
32     13 /api/.env
33
34 Top 5 User-Agents:
35     1199 Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like
36     856 Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/13
37     767 Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
38     122 Mozilla/5.0 (l9scan/2.0.9383e293e2239313e2231323; +https://leakix.net)
39     120 Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36

```

Листинг 3 – Сводка по журналу Caddy за 5 сентября – 8 октября

Рекомендации по улучшению безопасности удалённого сервера

- а) Запретить вход `root` по SSH (`PermitRootLogin no`), работать через обычного пользователя и `sudo`.
- б) Отключить вход по паролю (`PasswordAuthentication no`) и оставить только ключи: тогда подбор пароля бесполезен.
- в) Разрешить SSH только с известных адресов (например, из VPN) или закрыть порт 22 на firewall.
- г) Поставить систему защиты, которая блокирует источники перебора автоматически (см. отчёт №4.2).
- д) Не хранить в корне сайта файлы `.env`, `.git` и подобные – их ищут в первую очередь.

Выводы

Семантически работа подтвердила, что любой сервер с публичным адресом постоянно сканируют и пытаются взломать, что бы на нём ни размещалось. На SSH за 47,6 часа пришло 13 458 неудачных попыток с 64 адресов (283 в час), 72 % – под именем `root`. На веб-сервер первый сканер пришёл в день запуска, а за 33 суток 83 % запросов оказались поиском несуществующих файлов вроде `/.env`. Доступа никто не получил, но только благодаря стойкому паролю: вход `root` по паролю был разрешён намеренно.

С прагматической точки зрения журналы дают конкретный список мер: отключить вход `root` и пароли, ограничить адреса, блокировать источники перебора автоматически. Также видно, что журналы нужно анализировать до их ротации: данные за первые дни на сервере уже удалены, и сохранилась только сводка.